

Security incident report

Section 1: Identify the network protocol involved in the incident

The protocol associated with the incident is the Hypertext Transfer Protocol (HTTP). Since the problem involved accessing the web server for `yummyrecipesforme.com`, it indicates that communication between the users and the website relied on HTTP traffic. Additionally, when network traffic was analyzed using `tcpdump` while visiting the website, the captured logs displayed HTTP activity during communication with the server. The investigation also revealed that the malicious file was delivered to users' systems through HTTP at the application layer.

Section 2: Document the incident

Several users reported to the website's support team that after visiting the site, they were asked to download and execute a file advertised as providing access to new recipes. After running the file, users noticed that their computers began performing unusually slowly. At the same time, the website owner discovered they could no longer access the web server because they had been locked out of the administrator account.

To investigate the incident safely, a cybersecurity analyst accessed the website within a sandbox environment to avoid affecting the organization's network. The analyst also used `tcpdump` to capture and monitor the network traffic generated while interacting with the site. During the investigation, the analyst encountered a prompt encouraging the download of a file claiming to unlock free recipes. After downloading and executing the file, the browser redirected to a suspicious website named `greatrecipesforme.com`.

Upon reviewing the `tcpdump` logs, the analyst observed that the browser initially requested the IP address associated with `yummyrecipesforme.com`. After establishing an HTTP connection with the legitimate website and executing the downloaded file, the network activity changed unexpectedly.

The browser then requested a different IP address connected to greatrecipesforme.com, and the traffic was redirected to that malicious domain.

Further analysis by the senior cybersecurity professional included examining both the website source code and the downloaded file. The investigation revealed that an attacker had inserted malicious code into the website, causing visitors to download malware disguised as a browser update. Since the website owner had been locked out of the administrator account, the team concluded that the attacker likely gained access through a brute force attack and changed the administrator credentials. As a result, the malicious file compromised the systems of affected users.

Section 3: Recommend one remediation for brute force attacks

One security control the team intends to introduce to reduce the risk of brute force attacks is preventing users from reusing previous passwords. Since the attacker was able to exploit a default password to gain access, restricting the reuse of old or default credentials can help eliminate this weakness.

Another recommended measure is enforcing more frequent password changes. Regular password updates reduce the likelihood that compromised credentials can be used for an extended period of time by unauthorized individuals.

In addition, the organization plans to implement two-factor authentication (2FA). With 2FA enabled, users must verify their identity through two separate methods, typically a password and a one-time passcode (OTP) delivered to their email or mobile device. Access is granted only after both authentication steps are successfully completed. This added layer of security makes brute force attacks significantly less effective because obtaining the password alone would not be enough to access the system.

